Quiz — OWASP lab

Fillable quiz — type answers in the fields. Blank copies are already under `my-work/quizzes/`; answer them in place. Answer keys are not included.

1. How / scenario: IDOR on hold release — which API Top 10 family, and **why** does object-level authz matter more than “user was logged in”?

2. Spot the bug / why: CI builds images but never runs pip-audit/govulncheck. What fails on the job when a CVE drops?

3. Why: What does an SBOM (e.g. from Syft) help you answer after a CVE announcement?

4. Ethics: Is testing Juice Shop on a corporate shared cluster in-scope here? What should you do instead?

5. Why: Why map findings to mitigations instead of only collecting screenshots?

6. Scenario: A webhook-driven gateway fetches a user-supplied URL. Which risk class (e.g. SSRF) applies, and **how** would you constrain it?